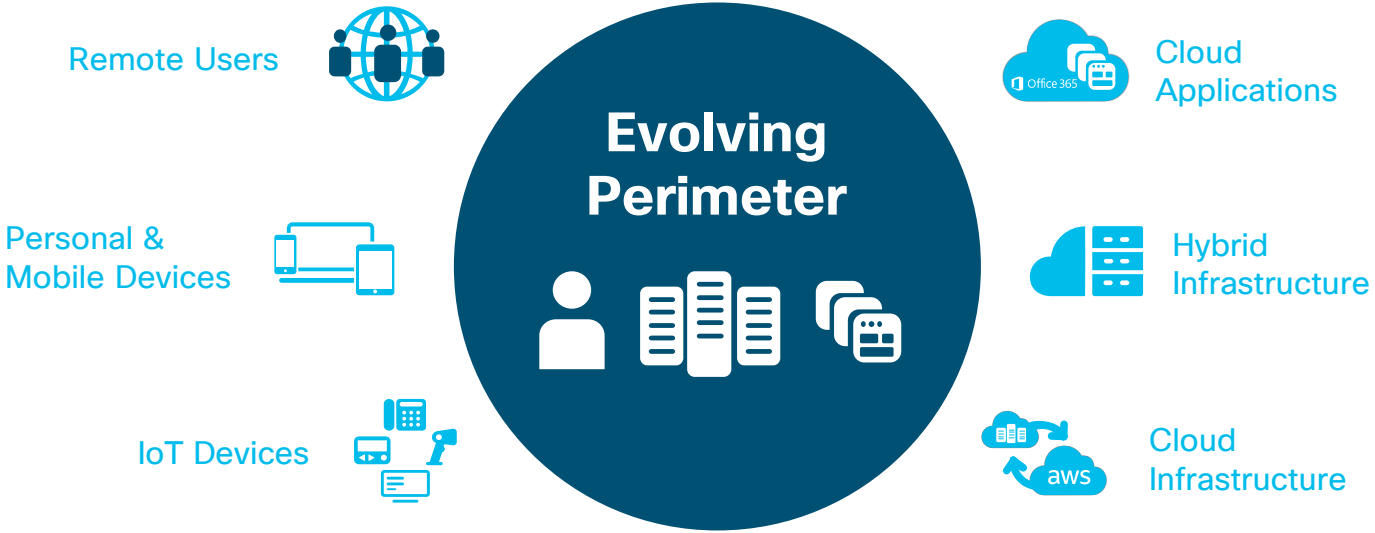
Shift in IT Landscape

Users, devices and apps are everywhere



© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

A little bit of Zero Trust history

Jericho Forum	ZT	BeyondCorp	CARTA & ZTX	ZTA
2004	2010	2014	2017	TODAY

De-perimiterization

An international group of corporate CISOs and vendors (Cisco hosted initial meeting)

Focused on solving “de-perimiterization” problem

Early output calling for “the need for trust”

Multiple Models Emerge

Forrester coined Zero Trust.

Google published their ZT solution as BeyondCorp

Forrester then expands to Zero Trust eXtended

Gartner names their model Continuous Adaptive Risk and Trust Assessment

Generalized

The industry has largely accepted Zero Trust Architecture as the general term

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Zero Trust is mis-named

Zero Trust
really means
"*Least-Privilege Access*"
(i.e. grant access,
but make it specific!)

But, there is
a lot more to
it than just that...

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Before we go further, let's level set:

There is a big difference between Authentication (AuthN) and Authorization (AuthZ)

 © 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Zero Trust changes the paradigm

- Focuses on data protection, not on attacks
- Assumes all environments are hostile and breached
- No access until user + device is proven “trusted”
- Authorize and encrypt all transactions and flows

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

True Zero Trust Architecture has hard-requirements

- The network is always assumed to be hostile
- External and Internal threat exists at all times
- Every device, app, user, and network flow is authenticated and authorized
- Automation systems are what allow a zero trust network to be built and operated
- Policies must be dynamic and calculated from as many sources of data as possible
- All activity is logged
- Trust is temporary

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Complementary security approaches

Threat-Centric

Basic security maturity to prevent attacks via an intelligence-based policy – then detect, investigate, and remediate

Dynamic Context

Trust-Centric

Good security practice to verify before granting access via a identity-based policy – for any user, any device, any app, in any location

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

The original three tenets of a Zero Trust network

Eliminate network trust

Assume all traffic, regardless of location, is threat traffic until it is verified that it is authorized, inspected, and secured.

Segment network access

Adopt a least privilege strategy and strictly enforce access control to only to the resources users need to perform their job.

Gain network visibility and analytics

Continuously inspect and log all traffic internally as well as externally for malicious activity with real-time protection capabilities.

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Three key new pillars of Zero Trust eXtended

Zero-trust people

Authenticate users and continuously monitor and govern their access and privileges. Secure users as they interact with the internet.

Zero-trust workloads

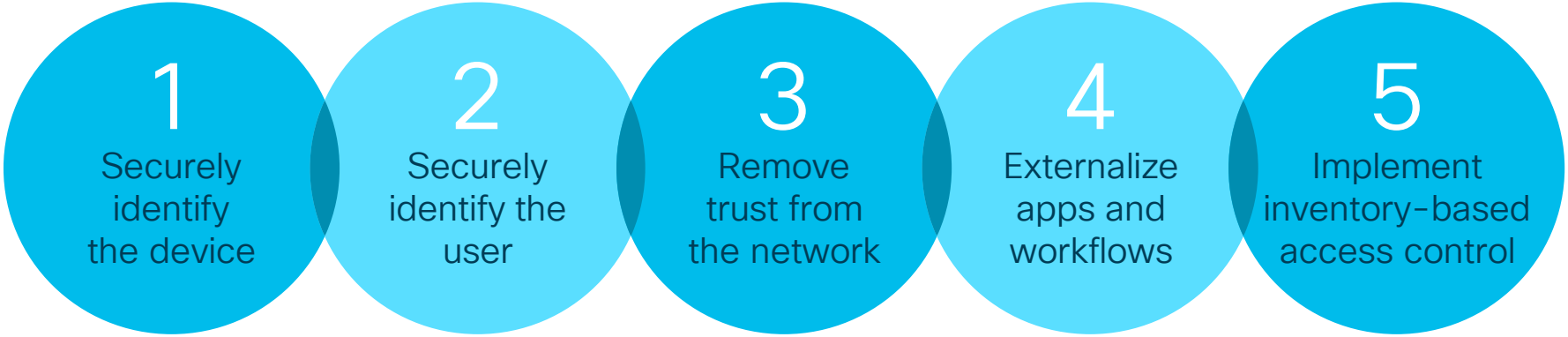
Enforce controls across the entire app stack, especially connections between containers or hypervisors in the public cloud.

Zero-trust data

Secure and manage data, categorize and develop data classification schemas, and encrypt data both at rest and in transit.

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Google's BeyondCorp implementation of Zero Trust



© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

For Your Reference

Google's BeyondCorp implementation of Zero Trust

1 Securely identify the device

Build a meta-inventory database of "managed device" identities using device certificates, which are issued upon a qualification process with periodic reviews.

2 Securely identify the user

Generate short-lived authorisation tokens using a centralized SSO portal with MFA, which validates identity against an user and group database.

3 Remove trust from the network

RADIUS servers dynamically assign "managed devices" to an unprivileged net or "unmanaged devices" to a guest net via 802.1x auth, which checks for device certs (#1).

4 Externalize apps and workflows

An internet-facing reverse access proxy enforces encryption between the client and application for all web-based apps via CNAME (public DNS) records.

5 Implement inventory-based access control

Per app access request, enforce service-level authorization by first interrogating multiple data sources to dynamically infer the level of device or user trustworthiness.

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Google's BeyondCorp Implementation of Zero Trust

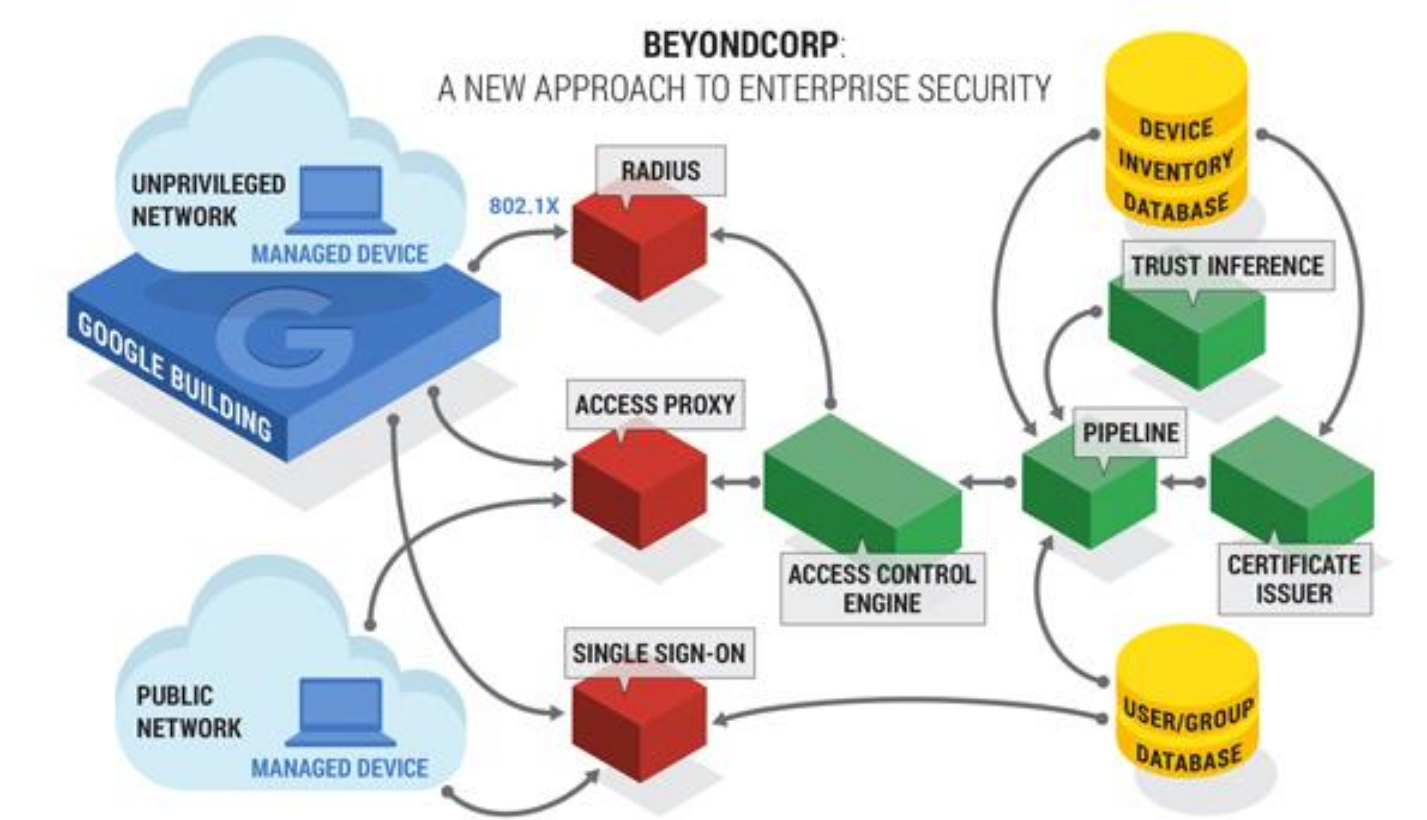
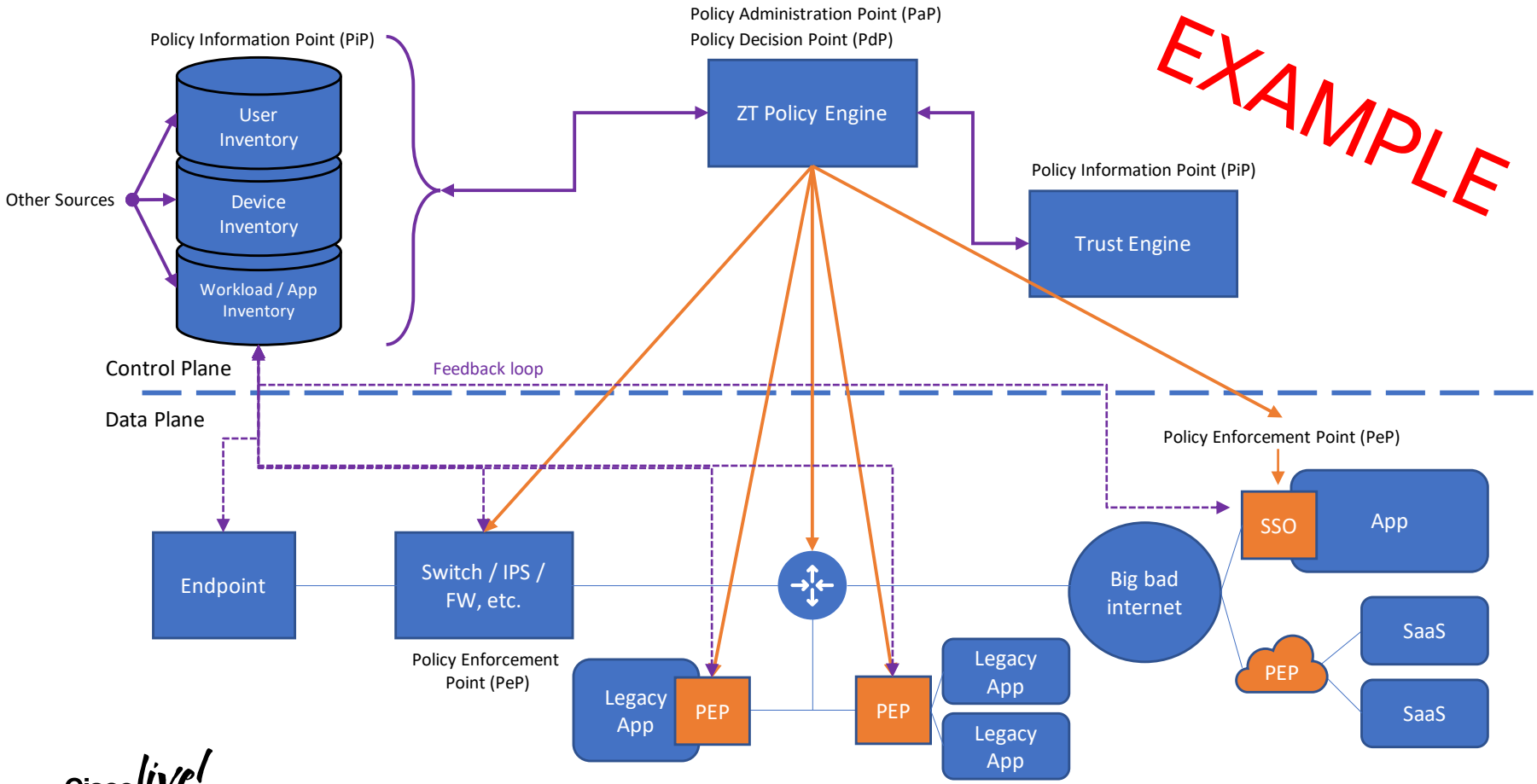


Image credit: Google

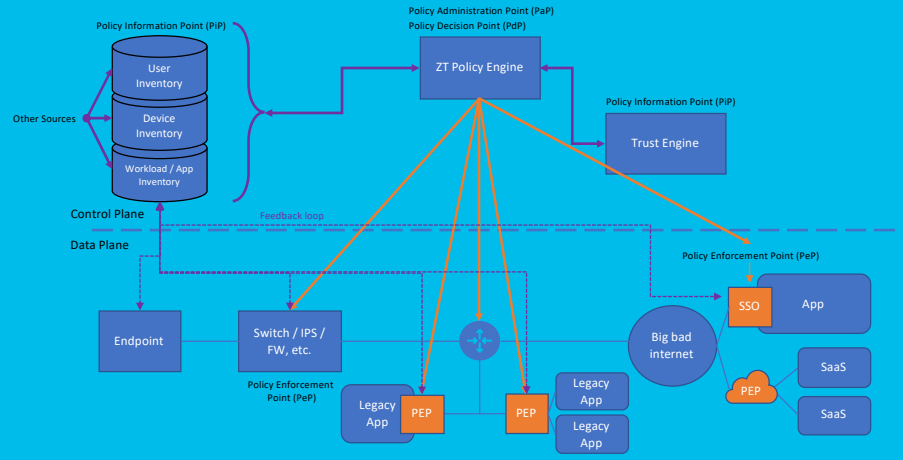
© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

True ZT Architecture



© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

ZT Architecture



- "**Perimeterless**" architecture
- **Deny all** access **until explicitly allowed**
- **All** users, devices, infrastructure, applications, services, etc. are **authenticated**
- All access is **authorised by** centralised **real-time policy engine**
- **Collect contextual data** on users, devices, infrastructure, applications, etc.
- Correlate contextual data and use ML to **evaluate trust & risk**

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Today vs Zero Trust

Today	Threat-Centric	Time-Bound	Static Policy
	Security primarily focused on prevention of malware and malicious attackers	Once authorized, identity and access is valid for lengthy periods typically	Policies are not aware of current and past context and access does not adapt based on context changes
Zero Trust	Trust-Centric	Per-Transaction	Dynamic Policy
	Security focused on granting and restricting access to data	Every user, device, and app must be authenticated and authorization requires trust/risk assessed per-flow & transaction	Policies adapt per user, device, and app context per current transaction relative to past transactions

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

For Your Reference

Nugget of Info:

of in-field malware detections from AMP for endpoint

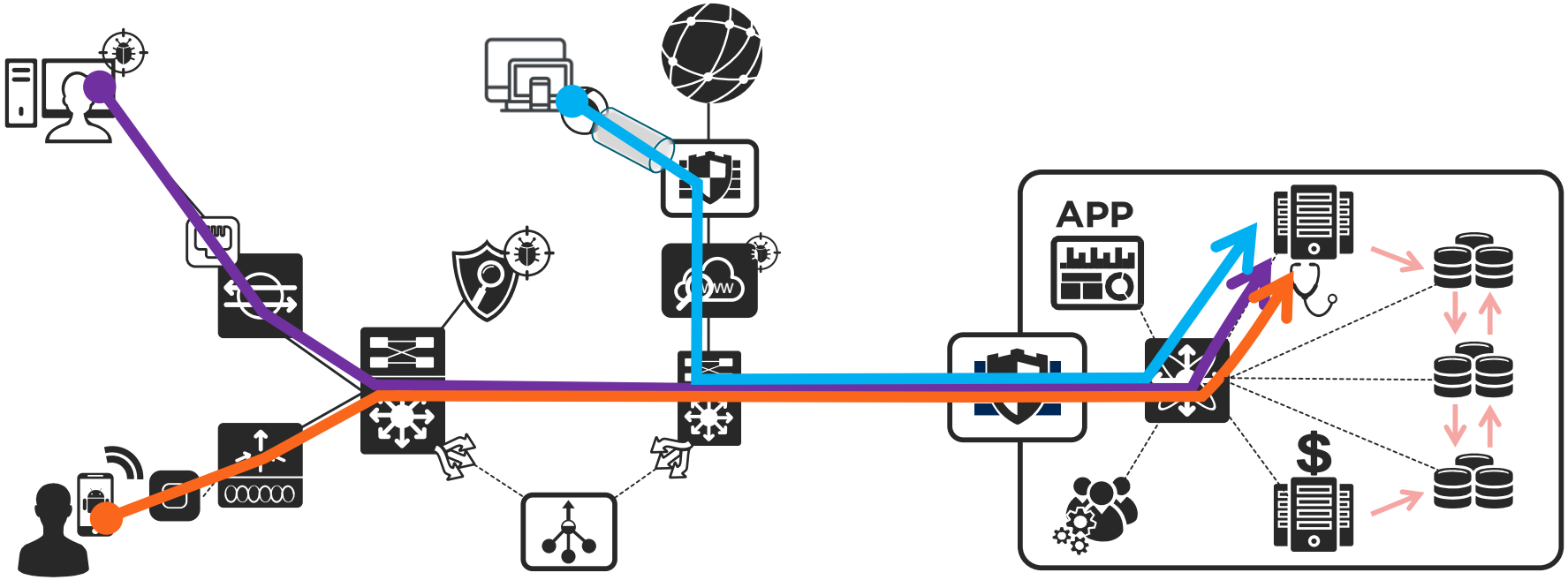
For last 7 days:	
Linux	5,597
macOS	13,679
Windows	1,376,949

For last 30 days:	
Linux	38,796
macOS	65,060
Windows	7,398,396

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Existing Environments (Pre-ZT)

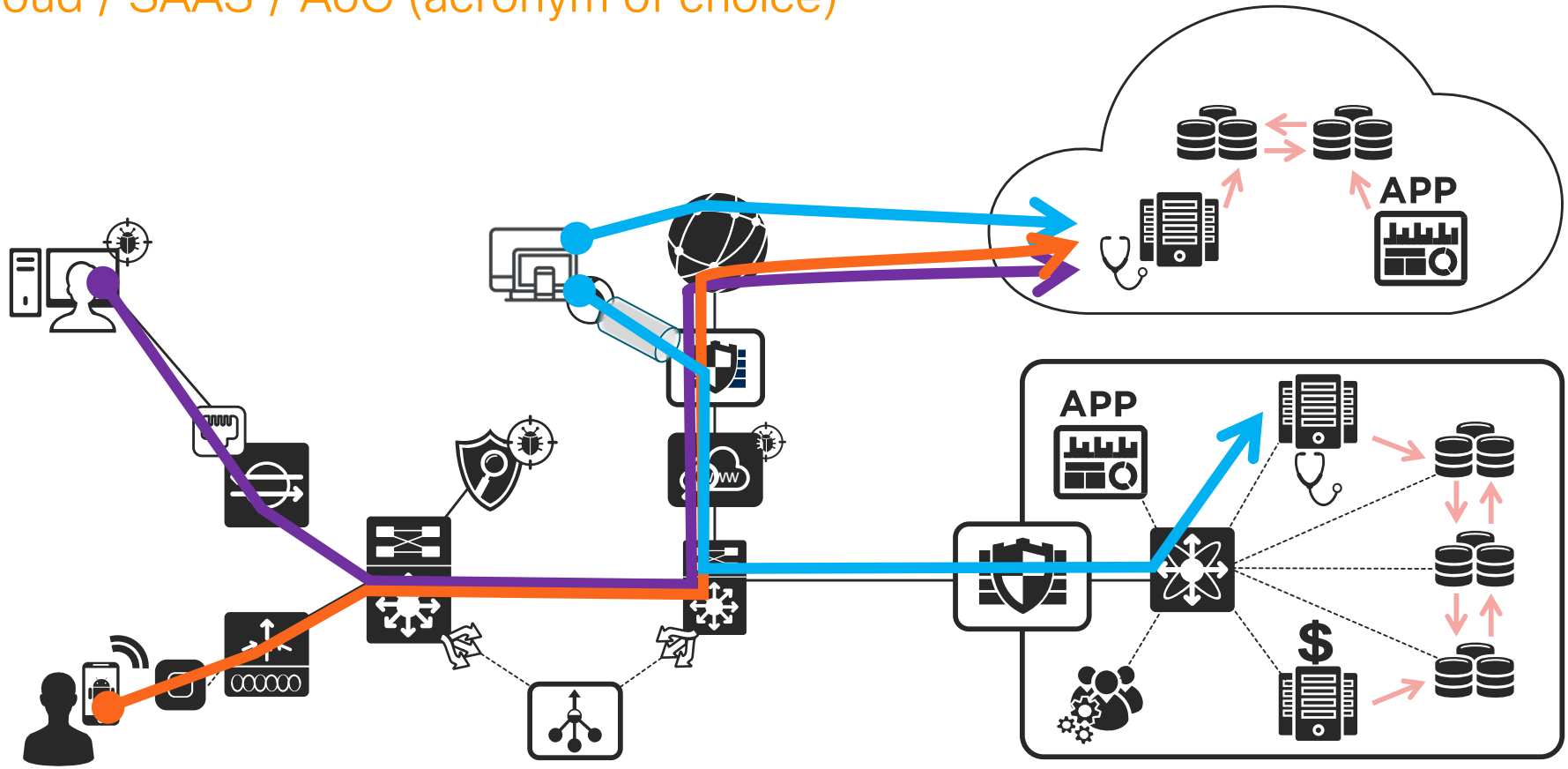
For Your Reference



 © 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Existing environments (pre-ZT)

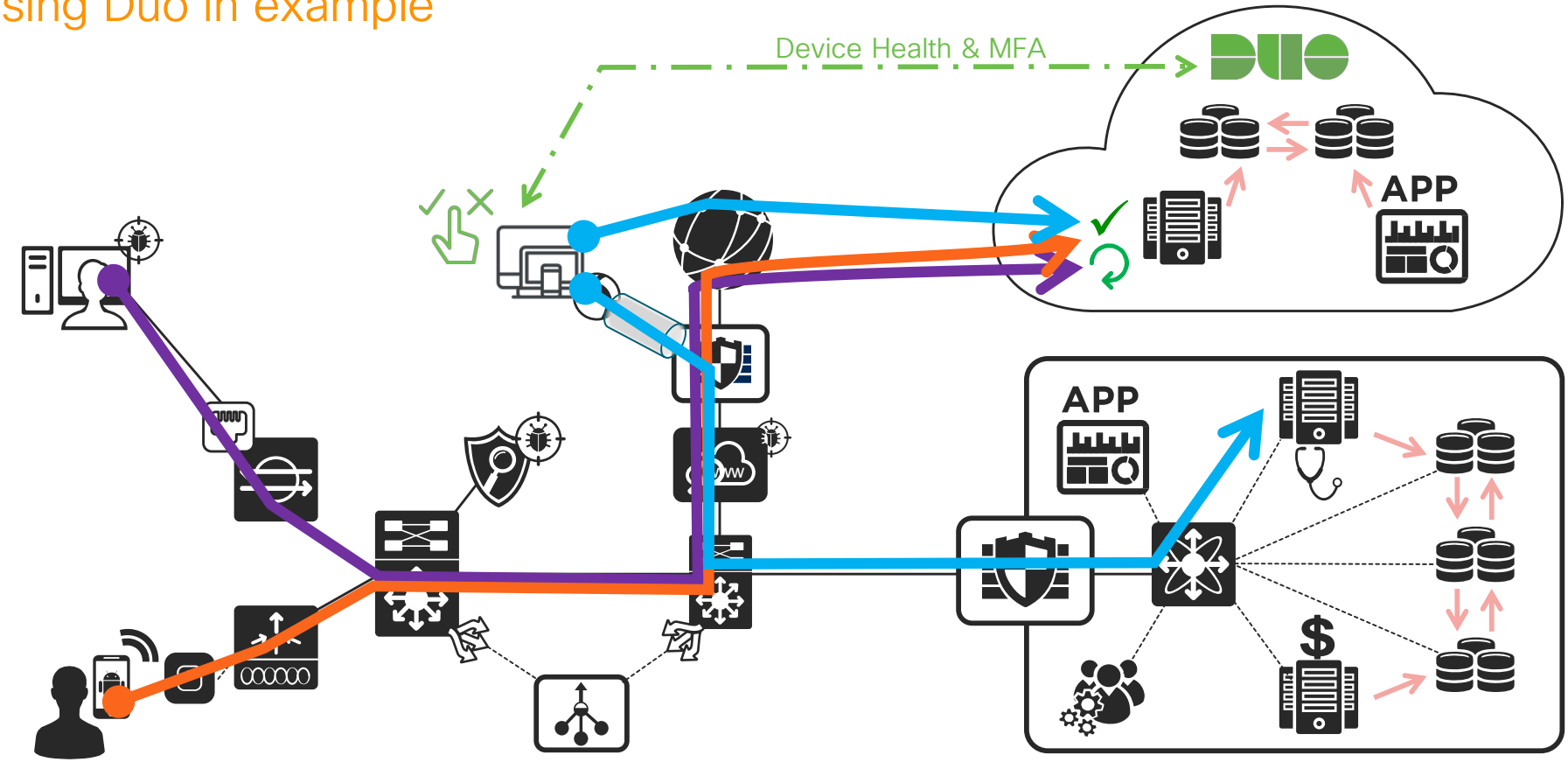
Cloud / SAAS / AoC (acronym of choice)



 © 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

Environments w/ Zero Trust

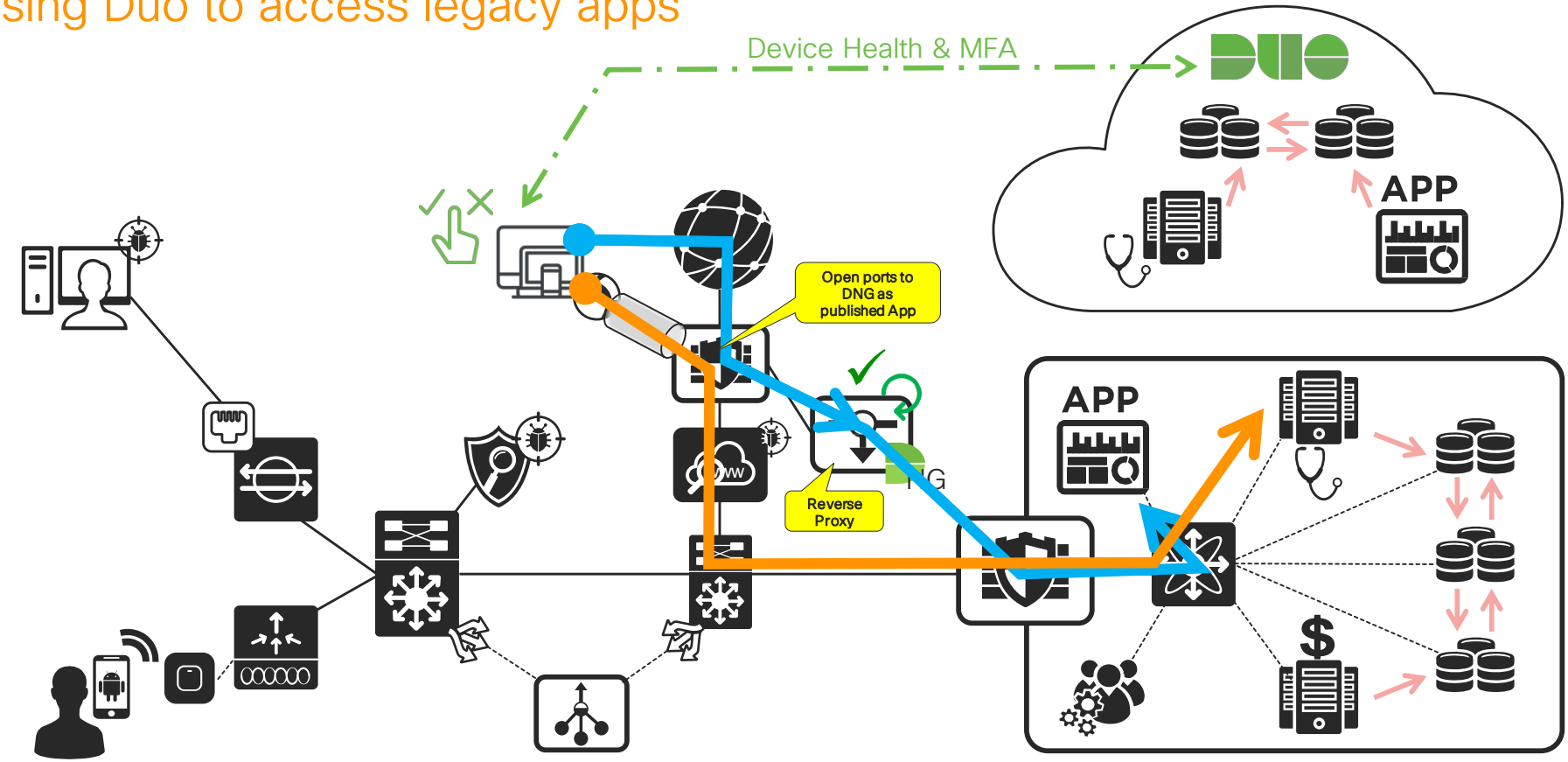
Using Duo in example



 © 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

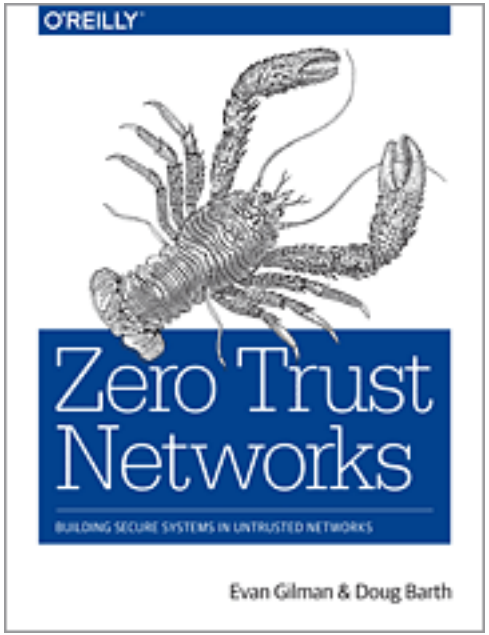
Environments w/ Zero Trust

Using Duo to access legacy apps



 © 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public

ZTN Book



- O'Reilly book on ZTN
  - Not perfect, but a great place to start
  - https://www.amazon.com/__/dp/1491962194?tag=oreilly20-20

© 2019 Cisco and/or its affiliates. All rights reserved. Cisco Public